

VULNERABILITY ASSESSMENT REPORT

OWASP Juice Shop — Lab Target (127.0.0.1:3000)

Maincrafts Technology — Cybersecurity & Ethical Hacking Internship, Task-3

Prepared by – Abhishek Verma

1. Executive Summary

This report documents a vulnerability assessment performed against an isolated lab target (127.0.0.1) running the OWASP Juice Shop intentionally-vulnerable web application on port 3000, as part of Task-3 of the Cybersecurity & Ethical Hacking internship. The assessment followed a standard reconnaissance-to-reporting workflow: host discovery, port and service enumeration, web server misconfiguration scanning, and hidden content discovery.

The assessment identified 8 distinct findings ranging from Critical to Informational severity. The most significant issues involve direct exposure of sensitive files — including an authentication credentials file (.htpasswd) and shell command history files — which, on a real production system, could hand an attacker credentials or a map of prior administrative activity without any exploitation required. Several standard HTTP security headers were also missing, and the application returns overly permissive Cross-Origin Resource Sharing (CORS) headers.

No exploitation was performed during this engagement; all findings represent identification and documentation only, per the defined scope. Task-4 will cover exploitation and deeper web security testing.

Severity	Count of Findings
Critical	2
High	0
Medium	3
Low	2
Informational	1

2. Methodology

Assessment Approach: A staged, passive-to-active scanning methodology was used, moving from host confirmation through to service fingerprinting and application-layer misconfiguration discovery — consistent with a standard external vulnerability assessment workflow.

2.1 Rules of Engagement

- Target restricted strictly to the isolated lab environment (127.0.0.1) — no systems outside the lab were scanned.
- Only passive and active scanning permitted; no exploitation, no denial-of-service, no data modification.
- All activity conducted from a Kali Linux attack workstation within the lab.

2.2 Tools Used

Tool	Version	Purpose
Nmap	7.95	Host discovery, port & service/version enumeration
Nikto	2.6.0	Web server misconfiguration & vulnerability scanning

Tool	Version	Purpose
Dirsearch	0.4.3	Hidden file & directory discovery via wordlist brute force

2.3 Activities Performed

- Step 1 — Host Discovery: confirmed the target host was live using an Nmap ping sweep.
- Step 2 — Port & Service Enumeration: full TCP port range scan (-p-) with service/version detection (-sV).
- Step 3 — Web Vulnerability Scan: Nikto scan against the identified web service on port 3000.
- Step 4 — Hidden Endpoint Discovery: Dirsearch brute-force scan against the web root using the default wordlist (11,460 entries) across php/asp/jsp/html/js extensions.

3. Technical Findings

Findings are ordered by risk rating, from Critical to Informational. Each finding includes the raw evidence line(s) captured during scanning.

F-01 Sensitive Authentication File Exposed (.htpasswd)

Risk Rating	Critical	Detected By	Nikto
-------------	----------	-------------	-------

Description

The web server serves the .htpasswd file directly to unauthenticated requests. This file is normally used to store HTTP Basic Authentication credentials (usernames and hashed passwords) and should never be reachable from outside the server's configuration directory.

Evidence

```
+ GET /.htpasswd: Contains authorization information.
```

Impact

If populated, this file would hand an attacker a set of credential hashes to crack offline, potentially leading to direct authentication bypass on any resource protected by HTTP Basic Auth, or reused-password compromise elsewhere.

Remediation

Move .htpasswd (and all dotfiles) outside the web root. Add an explicit deny rule for dotfiles at the web server / reverse proxy layer (e.g. `location ~ /\. { deny all; }` in Nginx, or `<Files ".ht*"> Require all denied </Files>` in Apache).

F-02 Shell Command History Files Exposed (.bash_history / .sh_history)

Risk Rating	Critical	Detected By	Nikto
-------------	----------	-------------	-------

Description

Both .bash_history and .sh_history are retrievable via HTTP GET requests. Their presence indicates the web root is set to (or overlaps with) a user's home directory, exposing a full history of shell commands previously executed on the host.

Evidence

```
+ GET /.bash_history: A user's home directory may be set to the web root, the shell history was
retrieved.
+ GET /.sh_history: A user's home directory may be set to the web root, the shell history was
retrieved.
```

Impact

Command history frequently contains file paths, internal hostnames, database connection strings, and occasionally credentials typed directly on the command line — all of which give an attacker reconnaissance data and potential direct credential access.

Remediation

Reconfigure the web server document root to a dedicated, non-home directory containing only intended public assets. Audit and rotate any credentials that may have been typed in cleartext on the shell. Add dotfile-deny rules as in F-01.

F-03 Missing HTTP Security Headers

Risk Rating	Medium	Detected By	Nikto
--------------------	---------------	--------------------	-------

Description

The application does not send several security-relevant HTTP response headers: Content-Security-Policy (CSP), Strict-Transport-Security (HSTS), Referrer-Policy, and Permissions-Policy.

Evidence

```
+ GET /: Suggested security header missing: strict-transport-security.
+ GET /: Suggested security header missing: content-security-policy.
+ GET /: Suggested security header missing: referrer-policy.
+ GET /: Suggested security header missing: permissions-policy.
```

Impact

Absence of CSP increases exposure to Cross-Site Scripting (XSS) impact by allowing arbitrary inline/external script execution if an injection point is later found. Missing HSTS allows protocol-downgrade / SSL-stripping attacks over untrusted networks. Missing Referrer-Policy can leak URL data to third parties.

Remediation

Add the missing headers at the application or reverse-proxy layer, e.g. `Content-Security-Policy: default-src 'self'`, `Strict-Transport-Security: max-age=31536000; includeSubDomains`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy: geolocation=(), camera=()`, tuned to the application's actual needs.

F-04 Permissive CORS Configuration (Access-Control-Allow-Origin: *)

Risk Rating	Medium	Detected By	Nikto / Nmap
--------------------	---------------	--------------------	--------------

Description

The server responds with a wildcard Access-Control-Allow-Origin header, permitting any origin to make cross-origin requests and read responses via client-side JavaScript.

Evidence

```
+ GET /: Retrieved access-control-allow-origin header: *.
Access-Control-Allow-Origin: * (confirmed in Nmap service banner)
```

Impact

If any endpoint returns session-sensitive or user-specific data, a wildcard CORS policy allows a malicious third-party site to read that data on behalf of a logged-in victim, undermining the same-origin protections the browser would otherwise provide.

Remediation

Restrict Access-Control-Allow-Origin to an explicit allow-list of trusted origins rather than '*', especially for any endpoint that returns authenticated or user-specific data. Combine with 'Access-Control-Allow-Credentials' only where strictly required.

F-05 Verbose Server Errors on /api Endpoints

Risk Rating	Medium	Detected By	Dirsearch
--------------------	---------------	--------------------	-----------

Description

A very large number of paths under /api/ (e.g. /api/, /api/v1/, /api/config, /api/swagger.json) return HTTP 500 Internal Server Error rather than a clean 404, each with a consistent ~2KB error body.

Evidence

```
500    2KB    http://127.0.0.1:3000/api
500    2KB    http://127.0.0.1:3000/api/config
500    2KB    http://127.0.0.1:3000/api/v1/
500    2KB    http://127.0.0.1:3000/api/swagger.json
... (40+ additional /api/* paths returning HTTP 500)
```

Impact

Consistent 500 responses across unrelated paths suggest error handling is not distinguishing 'not found' from 'server fault', and may indicate stack traces or internal error detail is being generated (even if not rendered in this response body). This pattern also makes it harder to distinguish real misconfigurations from noise during future scanning.

Remediation

Implement proper routing so undefined API paths return HTTP 404, and ensure a global error handler returns generic, non-verbose error messages to clients while logging full detail server-side only.

F-06 Information Disclosure via Custom Header (X-Recruiting)

Risk Rating	Low	Detected By	Nikto
--------------------	------------	--------------------	-------

Description

The server returns a non-standard X-Recruiting header pointing to an internal-style route (/#/jobs). While low-risk on its own, it is an example of unnecessary information being exposed in HTTP responses.

Evidence

```
+ GET /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
```

Impact

Minimal direct impact, but contributes to attacker reconnaissance by revealing application routes and internal conventions that would not otherwise be advertised.

Remediation

Remove custom/non-standard headers from production responses unless they serve a defined operational purpose.

F-07 Discoverable Sensitive-Sounding Directories (/ftp/, /public/) and robots.txt Disclosure

Risk Rating	Low	Detected By	Nikto
--------------------	------------	--------------------	-------

Description

Nikto flagged /ftp/ and /public/ as directories worth manual review, and robots.txt discloses at least one entry intended to guide (or in this case inform) crawlers/attackers about paths of interest.

Evidence

```
+ GET /ftp/: This might be interesting.
+ GET /public/: This might be interesting.
+ GET /robots.txt: contains 1 entry which should be manually viewed.
```

Impact

These directories may expose uploaded files, backups, or configuration data if not properly access-controlled. robots.txt itself is not a security control and commonly acts as a roadmap for attackers.

Remediation

Manually review the contents of /ftp/ and /public/ and apply authentication or access restrictions to anything not intended for public access. Do not rely on robots.txt to hide sensitive paths — enforce access control server-side instead.

F-08 Unidentified Secondary Service on Port 43739

Risk Rating	Informational	Detected By	Nmap
--------------------	----------------------	--------------------	------

Description

A full-port Nmap scan identified a second open TCP port (43739) running a Golang net/http server. The service responds to all tested requests with a generic 404 'Page Not Found' message and could not be automatically fingerprinted as a known product.

Evidence

```
43739/tcp open  http      Golang net/http server
404: Page Not Found (returned for GenericLines, GetRequest, HTTPOptions, and other probes)
```

Impact

An unidentified, undocumented service increases the attack surface and should be inventoried. Until identified, it is not possible to assess whether it exposes further functionality (e.g. debug/metrics endpoints) beyond the generic 404 response observed.

Remediation

Identify the process and purpose of the service bound to port 43739 on the host. If not required to be network-facing, bind it to localhost only or disable it. If required, apply the same header, CORS, and error-handling hardening recommended above.

4. Impact Analysis

Taken together, the findings in this assessment describe a target with weak information-hygiene at the file-serving layer and incomplete security header/CORS hardening at the application layer. On a real (non-lab) deployment, the combination of F-01 and F-02 is the most concerning: an attacker requires no exploitation at all — a single unauthenticated GET request — to potentially obtain credential material and a record of prior administrative shell

activity. This represents a direct path to lateral movement or full compromise if the exposed data is live and reused elsewhere.

The Medium-severity findings (F-03 to F-05) do not grant direct access on their own, but they materially increase the impact of any future vulnerability discovered on the application — for example, an XSS bug would be far more damaging without a CSP in place, and the wildcard CORS policy would let any external site harvest data from authenticated sessions. The Low and Informational findings (F-06 to F-08) primarily aid attacker reconnaissance and should be remediated as part of general hardening, but do not represent an immediate risk on their own.

Overall Risk Posture: MEDIUM-HIGH, driven principally by the two Critical file-exposure findings.

5. Risk Rating Summary

ID	Finding	Severity	Tool
F-01	.htpasswd file exposed	Critical	Nikto
F-02	Shell history files exposed	Critical	Nikto
F-03	Missing HTTP security headers	Medium	Nikto
F-04	Wildcard CORS policy	Medium	Nikto/Nmap
F-05	Verbose 500 errors on /api paths	Medium	Dirsearch
F-06	X-Recruiting header disclosure	Low	Nikto
F-07	/ftp/, /public/, robots.txt disclosure	Low	Nikto
F-08	Unidentified service on port 43739	Informational	Nmap

6. Remediation Roadmap

Immediate (0-7 days)

- Remove or block access to .htpasswd, .bash_history, .sh_history and all dotfiles from the web root (F-01, F-02).
- Rotate any credentials that may have been exposed or typed on the affected host's shell.

Short-term (1-4 weeks)

- Implement CSP, HSTS, Referrer-Policy, and Permissions-Policy headers (F-03).
- Restrict CORS to an explicit origin allow-list (F-04).
- Fix API routing/error handling so unmatched paths return 404 with generic error bodies (F-05).

Longer-term (1-3 months)

- Remove non-standard/informational headers and review robots.txt content (F-06, F-07).
- Inventory and document the purpose of the service on port 43739, restricting network exposure if not required (F-08).
- Schedule recurring vulnerability scans (Nikto/Dirsearch/Nmap or OpenVAS) as part of ongoing security hygiene.

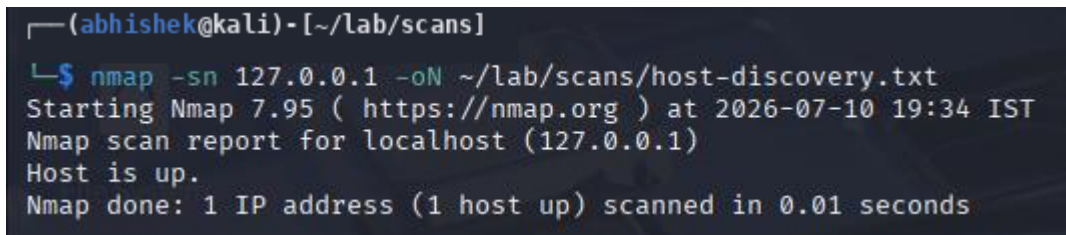
7. Conclusion

This assessment successfully completed all five required activities: host discovery, port/service enumeration, web misconfiguration scanning, hidden-content discovery, and consolidation of findings into this formal report. Eight findings were identified across Critical, Medium, Low, and Informational severities, with the two Critical findings — direct exposure of an authentication file and shell history files — representing the most urgent remediation priority.

No exploitation was carried out, consistent with the defined scope of this task. The next stage, Task-4, will build on this assessment by performing controlled exploitation and deeper web application security testing (e.g. against the OWASP Top 10) on the same lab target.

8. Appendix — Evidence Screenshots

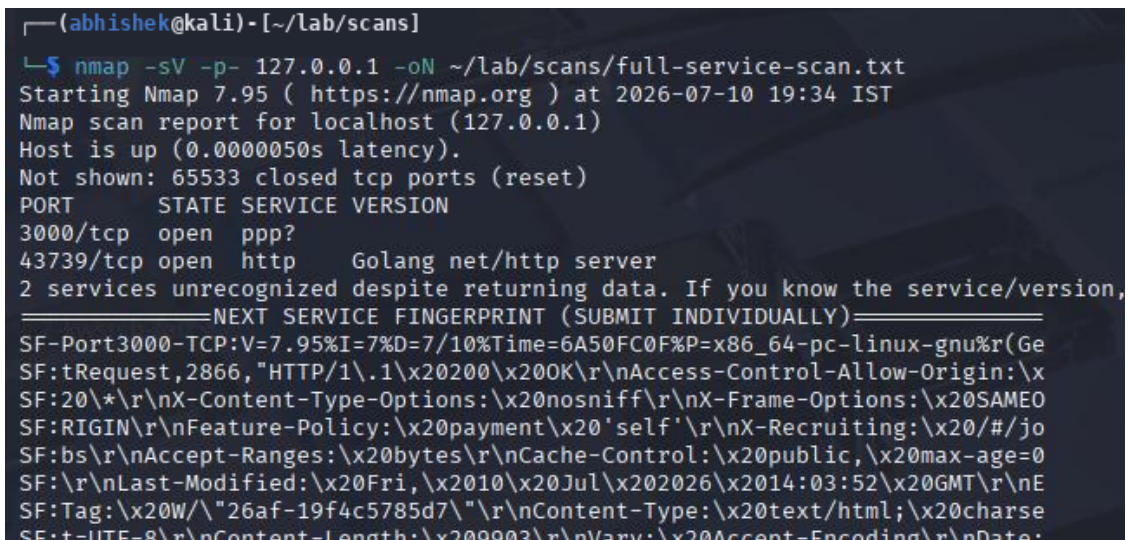
A. Host Discovery



```
(abhishek@kali) - [~/lab/scans]
$ nmap -sn 127.0.0.1 -oN ~/lab/scans/host-discovery.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 19:34 IST
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.01 seconds
```

Figure 1 — Nmap host discovery (-sn) confirming 127.0.0.1 is live.

B. Port & Service Enumeration



```
(abhishek@kali) - [~/lab/scans]
$ nmap -sV -p- 127.0.0.1 -oN ~/lab/scans/full-service-scan.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-10 19:34 IST
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
43739/tcp open  http   Golang net/http server
2 services unrecognized despite returning data. If you know the service/version,
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port3000-TCP:V=7.95%I=7%D=7/10%Time=6A50FC0F%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,2866,"HTTP/1\1\20200\200K\r\nAccess-Control-Allow-Origin:\x
SF:20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEO
SF:RIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/jo
SF:bs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0
SF:\r\nLast-Modified:\x20Fri,\x2010\x20Jul\x202026\x2014:03:52\x20GMT\r\nE
SF:Tag:\x20W/\x20"26af-19f4c5785d7"\r\nContent-Type:\x20text/html;\x20chase
SF:t=UTF-8\r\nContent-Length:\x209903\r\nVary:\x20Accept-Encoding\r\nDate:
```

Figure 2 — Full TCP port scan with service/version detection (-sV -p-).

C. Web Vulnerability Scan


```

[abhishek@kali]~/lab/scans
➤ nikto -h http://127.0.0.1:3000 -o ~/lab/scans/nikto.txt
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 3000
+ Platform: Unknown
+ Start Time: 2026-07-10 19:36:06 (GMT+5.5)

+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
+ [002739] /.htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.

```

Figure 3 — Nikto scan output against `http://127.0.0.1:3000`.

D. Hidden Endpoint Discovery

```

[abhishek@kali]~/lab/scans
➤ dirsearch -u http://127.0.0.1:3000 -t 5 -o ~/lab/scans/dirsearch.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 5 | Wordlist size: 11460
Output File: /home/abhishek/lab/scans/dirsearch.txt
Target: http://127.0.0.1:3000/

[19:50:16] Starting:
[19:51:36] 500 - 475B - /.well-known/security.txt
[19:51:37] 500 - 2KB - /api
[19:51:37] 301 - 158B - /api-docs → /api-docs/
[19:51:37] 500 - 2KB - /api-doc
[19:51:37] 500 - 2KB - /api.php
[19:51:37] 500 - 2KB - /api.log
[19:51:37] 500 - 2KB - /api/
[19:51:37] 500 - 2KB - /api.py
[19:51:37] 500 - 2KB - /api/2/explore/
[19:51:37] 500 - 2KB - /api/_/swagger_/
[19:51:37] 500 - 2KB - /api/2/issue/createmeta
[19:51:37] 500 - 2KB - /api/api
[19:51:37] 500 - 2KB - /api/_/swagger_/
[19:51:37] 500 - 2KB - /api/apidocs
[19:51:37] 500 - 2KB - /api/apidocs/swagger.json
[19:51:37] 500 - 2KB - /api/batch
[19:51:37] 500 - 2KB - /api/application.wadl
[19:51:37] 500 - 2KB - /api/config
[19:51:37] 500 - 2KB - /api/cash/graphql
[19:51:37] 500 - 2KB - /api/docs
[19:51:37] 500 - 2KB - /api/docs/
[19:51:37] 500 - 2KB - /api/index.html
[19:51:37] 500 - 2KB - /api/error_log
[19:51:37] 500 - 2KB - /api/sonews
[19:51:37] 500 - 2KB - /api/sonews/invoice

```

Figure 4 — Dirsearch scan output against `http://127.0.0.1:3000`.